

Entitlement For Composable AI

https://miro.com/app/board/uXjVH3Pw7Ew=

The urls

<https://www.crm-sync.dev/products/sbom-registry>

<https://www.crm-sync.dev/products/verified-transactions>

<https://www.crm-sync.dev/products/3d-publisher>

<https://www.crm-sync.dev/products/sbom-firmware-image>

<https://www.crm-sync.dev/products/cra-readiness>

<https://www.crm-sync.dev/products/asset-sample-model>

<https://www.crm-sync.dev/products/firmware-security>

<https://www.crm-sync.dev/products/channel-publish>

<https://www.crm-sync.dev/products/download-app>

<https://www.crm-sync.dev/products/sbom-registry>

<https://www.crm-sync.dev/products/verified-transactions>

<https://www.crm-sync.dev/products/3d-publisher>

<https://www.crm-sync.dev/products/sbom-firmware-image>

<https://www.crm-sync.dev/products/cra-readiness>

<https://www.crm-sync.dev/products/asset-sample-model>

<https://www.crm-sync.dev/products/firmware-security>

<https://www.crm-sync.dev/products/channel-publish>

<https://www.crm-sync.dev/products/download-app>

[https://miro.com/app/board/uXjVH3Pw7Ew=/
Strategy Board](https://miro.com/app/board/uXjVH3Pw7Ew=/)

CRM Sync — Firmware, SBOM & the Cyber Resilience Act

<https://www.crm-sync.dev/pages/knowledge-base#firmware-sbom-cra>

What is a software bill of materials (SBOM)?

<https://www.ibm.com/think/topics/sbom>

“How do you solve this problem for SAAS”?

Isaac Hepworth-Google

<https://youtu.be/ZYsUbN6oT7Q?si=FQ7VrPMuXdoGEGVy>

Against Liquid-served JS

Worth naming the actual comparison precisely, because it's the part that gets muddled: Liquid itself is server-rendered and trustworthy. The problem is JavaScript derived from Liquid values and executed in the buyer's browser. Six distinct properties differ:

1

Trust boundary

Client-side logic is advisory, never authoritative. Anything the browser computes becomes untrusted input the moment it's submitted back — cart attributes, line item properties, programmatic discount code application. Building pricing or eligibility logic there is client-side enforcement of a server-side rule, which is the oldest broken-access-control pattern there is. Functions execute where the decision is actually made, and the buyer cannot reach them.

2

Logic disclosure

Margin thresholds, B2B tier rules, bundle eligibility, fraud heuristics — all of it sits in page source, readable in DevTools. A Function's compiled Wasm never leaves Shopify's infrastructure.

3

Data exposure —

The underrated one. `var tier = "{{ customer.tags }}"` puts internal segmentation into the DOM, where every other script on the page can read it: analytics, chat widgets, ad pixels, affiliate tags. And if it isn't piped through the json filter, an interpolated customer-supplied value is a stored XSS vector. Functions receive that same data server-side via the input query; it never enters the document.

4

Execution guarantee

Ad blockers, CSP violations, JS errors upstream, slow connections, race conditions with cart submission — client-side validation silently doesn't run some percentage of the time, and you don't get told. Functions run as part of cart evaluation and can't be skipped.

5

Change control

Theme Liquid gets edited in the admin by whoever has access, unversioned, unreviewed. Functions ship as versioned app extensions with rollback, and Shopify doesn't permit apps that provide dynamic editing and execution of function code — no arbitrary code paths.

6

Consent surface

Theme JS runs in the page and is subject to every consent obligation attached to it. Functions have no browser presence and no network capability, so they're outside that surface entirely. This is the same logic behind Web Pixels: unlike Additional Scripts, which ran arbitrary JavaScript directly in the page, Web Pixels run in an isolated iframe with restricted DOM access, and PII is passed through the API explicitly rather than scraped.

crm-sync.dev

[illegible][illegible][illegible][illegible]

Cyber Resilience Act

Compliance Calendar and BaaS Logging Required

Firmware Glossary

[HTTPS://CRM-SYNC.DEV/R/AFB95MM](https://CRM-SYNC.DEV/R/AFB95MM)

CRA Setup Guide

[HTTPS://CRM-SYNC.DEV/R/F4C4UTA](https://CRM-SYNC.DEV/R/F4C4UTA)

Shopify WASM

[HTTPS://SHOPIFY.ENGINEERING/SHOPIFY-WEBASSEMBLY](https://SHOPIFY.ENGINEERING/SHOPIFY-WEBASSEMBLY)

COMPLIANCE QA

The CRA, as a **setup guide**.

Most apps are "default category" under the Cyber Resilience Act — self-assessment, no external auditor. That makes compliance a checklist, not a project: ten documents, prepared in order, ahead of two dates. Tick them off as you go — progress is saved in this browser.

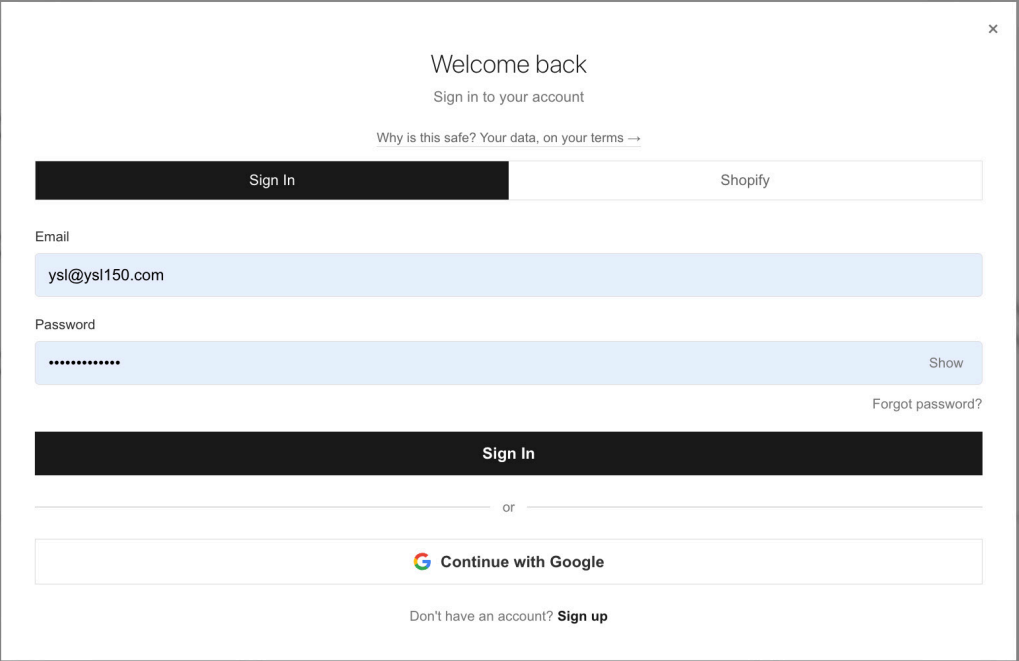
THE CALENDAR

IN FORCE	Omnibus price transparency (2019/2161) — show the lowest price of the prior 30 days with every discount.
IN FORCE	GDPR — personal data.
11 SEP 2026	CRA reporting begins — actively exploited vulnerabilities: early warning in 24 hours, notification in 72 hours, final report in 14 days.
11 DEC 2027	CRA full obligations — documentation, secure updates, conformity assessment, CE marking.
SAME DATES	Connected devices (Class I / II) — stricter conformity routes, identical clocks. If you sell anything with firmware, the device itself is in scope.

Entitlement

Shopify/Google/Xano auth me are connected logins

Aligned with server side data: GA4 v2, and Shopify GraphQL Functions



The image shows a login modal for CRM Sync. The modal is white with a close button (X) in the top right corner. It contains the following elements:

- Header:** "Welcome back" followed by "Sign in to your account".
- Link:** "Why is this safe? Your data, on your terms →".
- Buttons:** A black "Sign In" button and a white "Shopify" button.
- Email Field:** A light blue input field containing "ysl@ysl150.com".
- Password Field:** A light blue input field with masked characters "*****" and a "Show" button.
- Link:** "Forgot password?".
- Buttons:** A black "Sign In" button.
-
- or
- Google Login:** A white button with the Google logo and the text "Continue with Google".
- Footer:** "Don't have an account? **Sign up**".

The background of the page is a dark grey with the CRM Sync logo and navigation links (DIFFERENCE, HOW, MISSION, PRODUCTS, 3D, FIRMWARE, DOCS, Q, CART, LOGIN). The main heading "CRM" is visible in the top left, and the tagline "THE CRM YOUR ADS AND AI AGENTS CAN USE — NOT JUST YOUR TEAM" is below it. The background also features large, faint letters "S E N T" and a "CONNECT A SEGMENT" button.

Auth Me/Welcome

Shopify/Google/Xano auth me are connected logins
Aligned with server side data: GA4 v2, and Shopify GraphQL Functions

CRM

DIFFERENCEHOWMISSIONPRODUCTS3DFIRMWAREDOCSQ

CARTYOONSUN

Welcome to your account

Manage your profile, agents, privacy, and tokens. Sign in to enable the tabs — the same login carries into your agentic carts and checkouts.

MeAgentsPrivacyAgent Pay

Signed in asyoonsun lee

Emailyoonsunlee150@gmail.com

YOUR TAGS

No tags.

LICENSES

Granted	Terms	Proof
2026-07-27	distribution	receipt · verify · QR · SVG
2026-07-27	distribution	receipt · verify · QR · SVG

ACTIVITY LOG

Date	Interaction	Via
2026-07-29 02:12	consent granted	deferred_login
2026-07-29 02:12	consent granted	deferred_login
2026-07-29 02:12	consent granted	deferred_login
2026-07-29 02:12	consent granted	deferred_login
2026-07-29 02:12	Consent granted	
2026-07-29 02:12	Consent granted	

encrypted vault and only leaves through a two-step authorization gate. In between, three records outlive the transaction: a **registry row** (product, version, size, full SHA-256, linked SBOM), an **upload certificate** (Ed25519-signed proof of what was vaulted, by whom, when), and a **hash-chained access ledger** — every grant, every denial, every served byte-stream, each row sealing the one before it.

Payment Rails

Rails and Agents are equally secure

CRM

DIFFERENCEHOWMISSIONPRODUCTS3DFIRMWAREDOCSQ

CARTYOONSUN

Welcome to your account

Manage your profile, agents, privacy, and tokens. Sign in to enable the tabs — the same login carries into your agentic carts and checkouts.

Me

Agents

Privacy

Agent Pay

LINKED AGENTS

No agents authorized yet.

AUTHORIZE A NEW AGENT

Agent name (e.g. ChatGPT)

Limit — Max \$

Subject / stack (blank = all stacks)

UCP — commerce (agentic)

Cash App — manual

Venmo — manual

Kakao Pay — agentic

Google Pay — manual

Apple Pay — manual

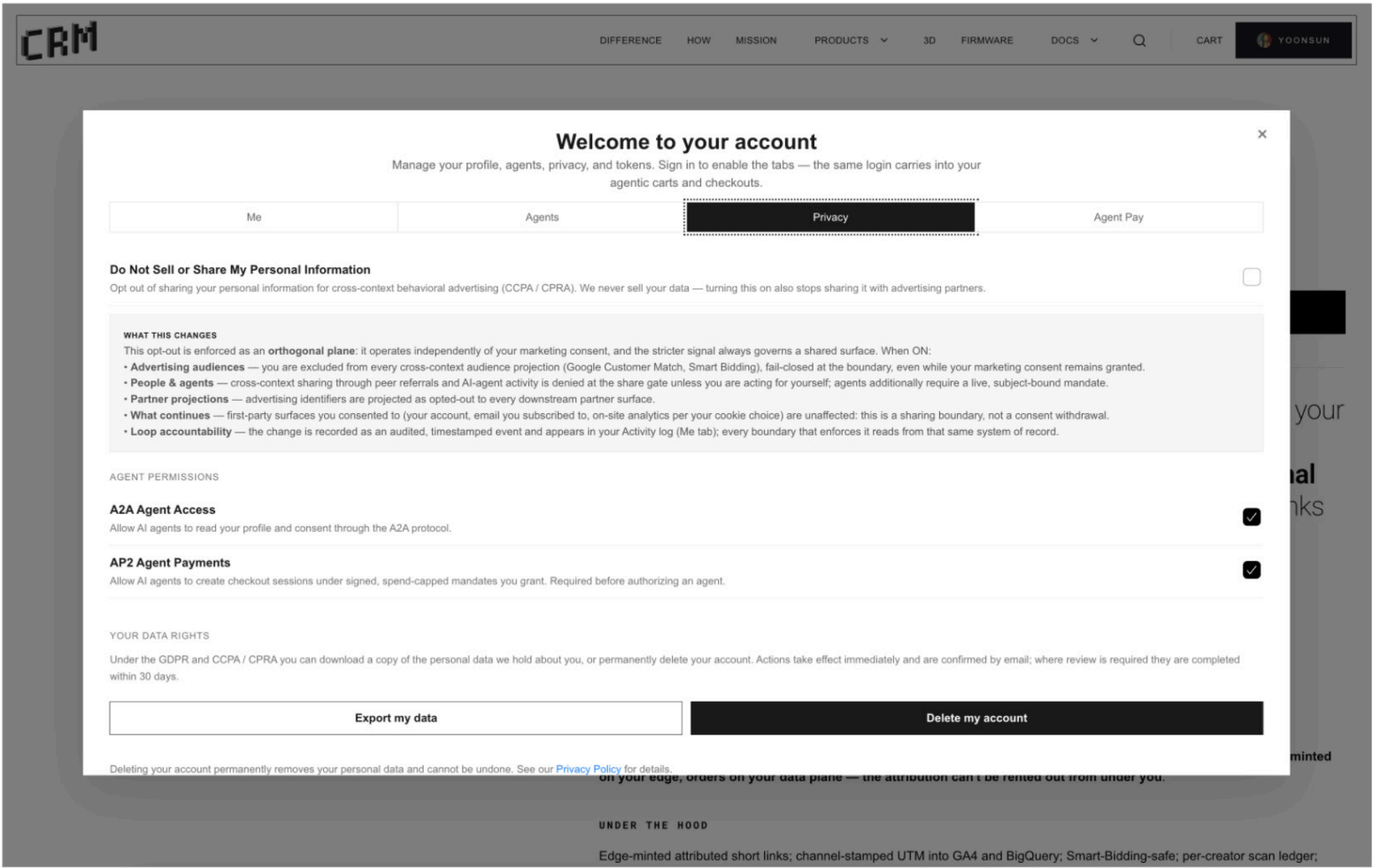
Samsung Pay — manual

• Pick a channel in the wizard, preview the QR tree, and mint the link in one click.

• Every scan carries channel-stamped tracking into your analytics — attribution intact.

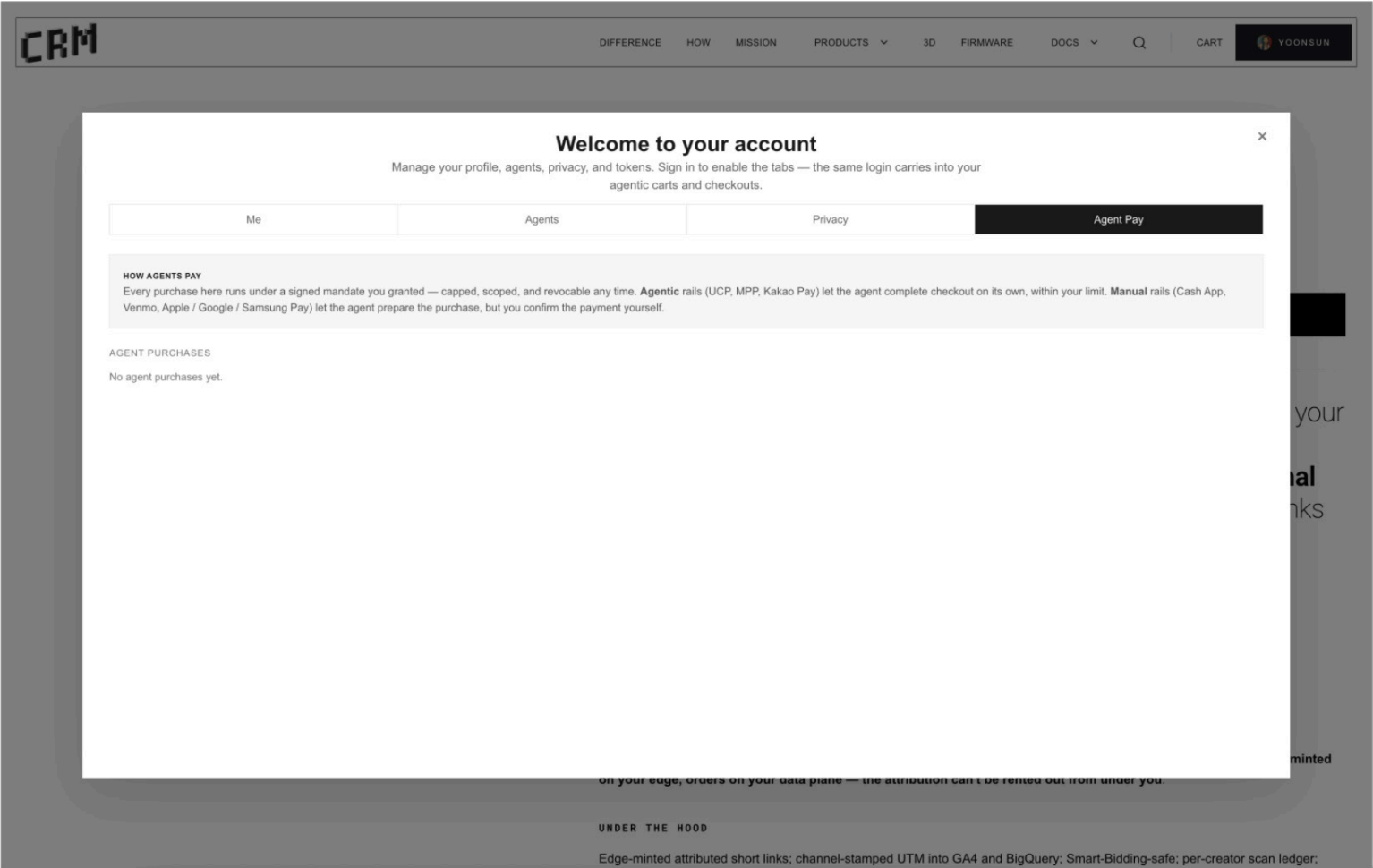
Data Redaction

Data Redaction with Verified timestamp and device.



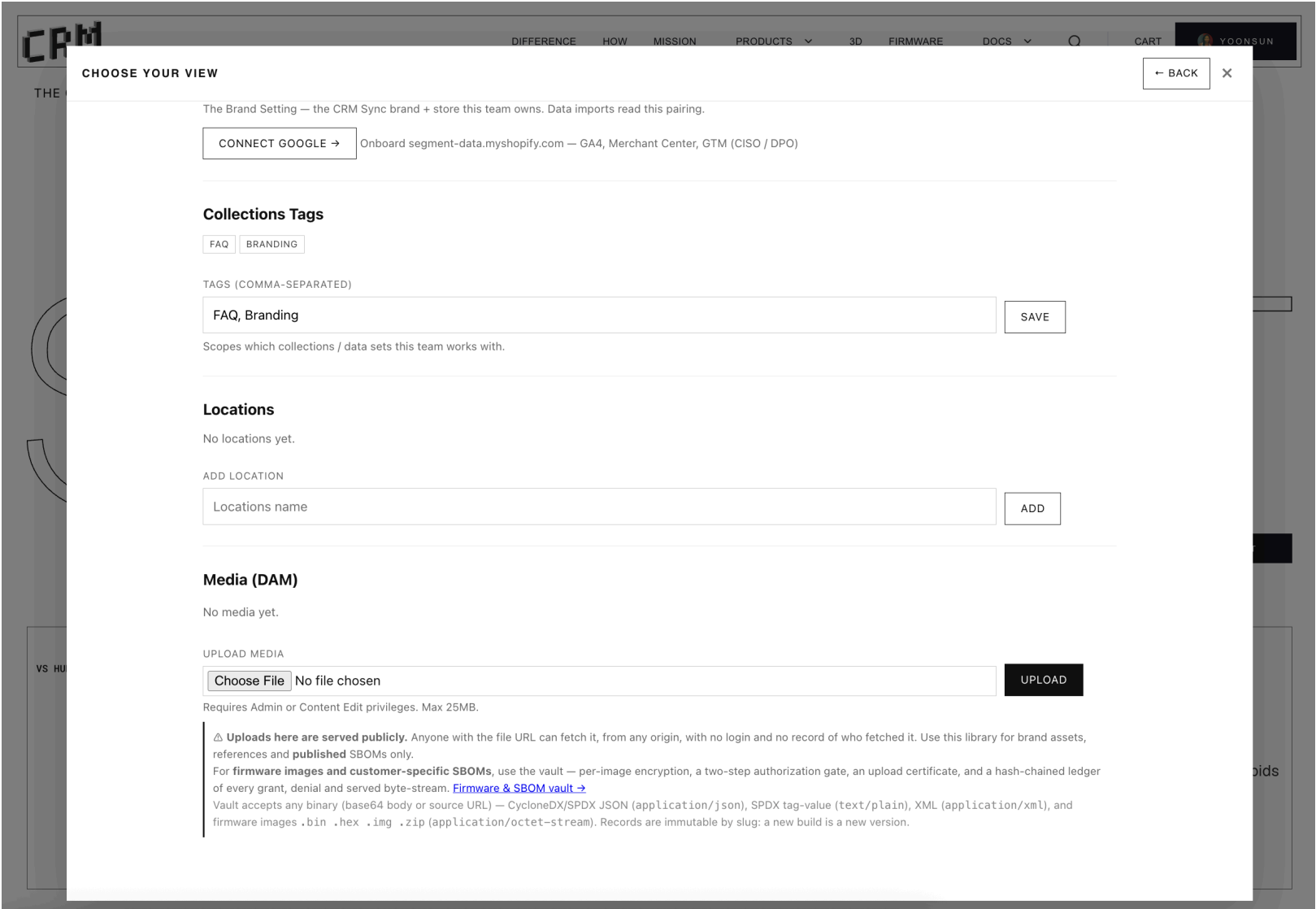
Agent Permissions

Transaction History and Transaction Limit restriction



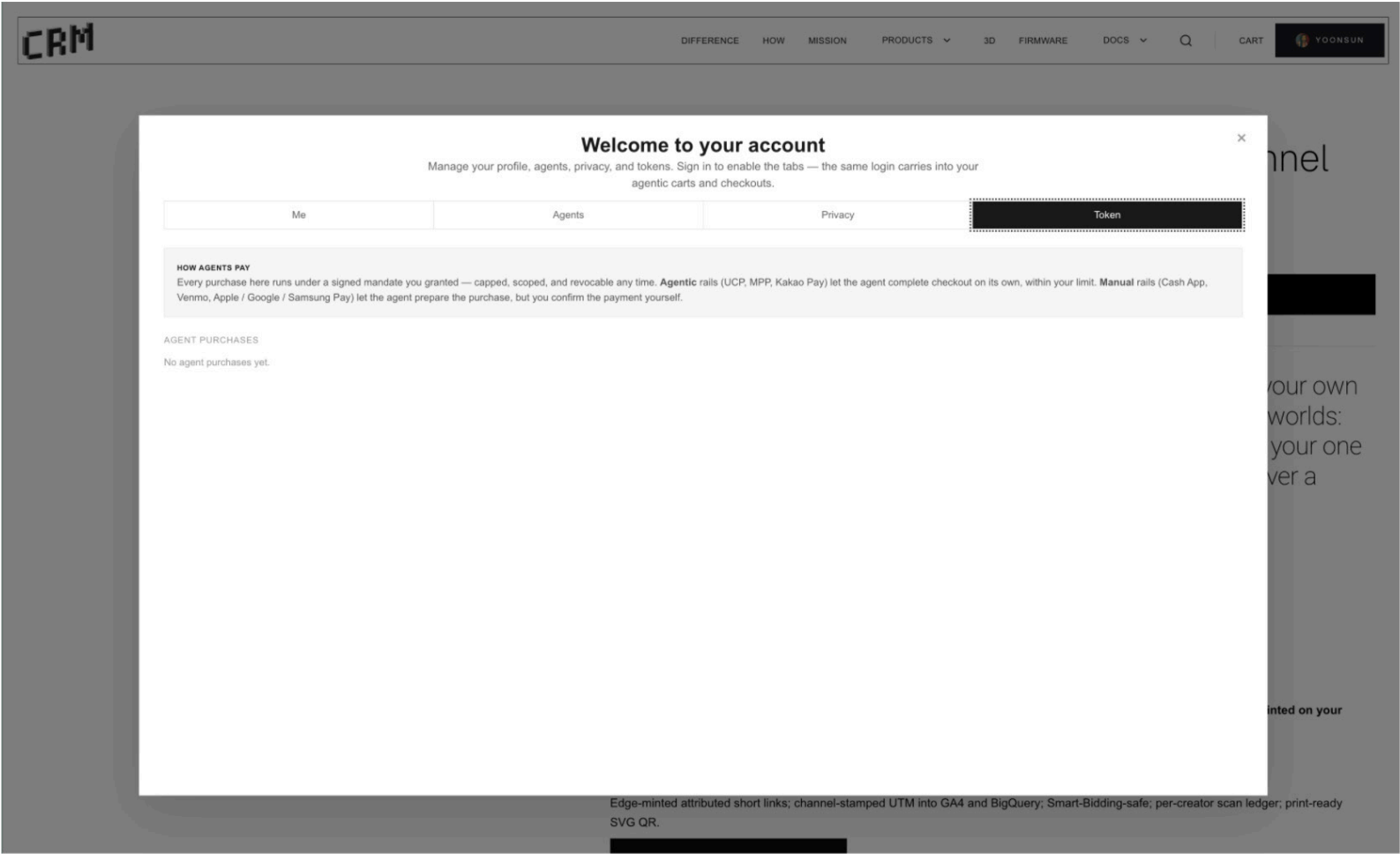
Tags and uploads

Public uploads are public files. For restricted access



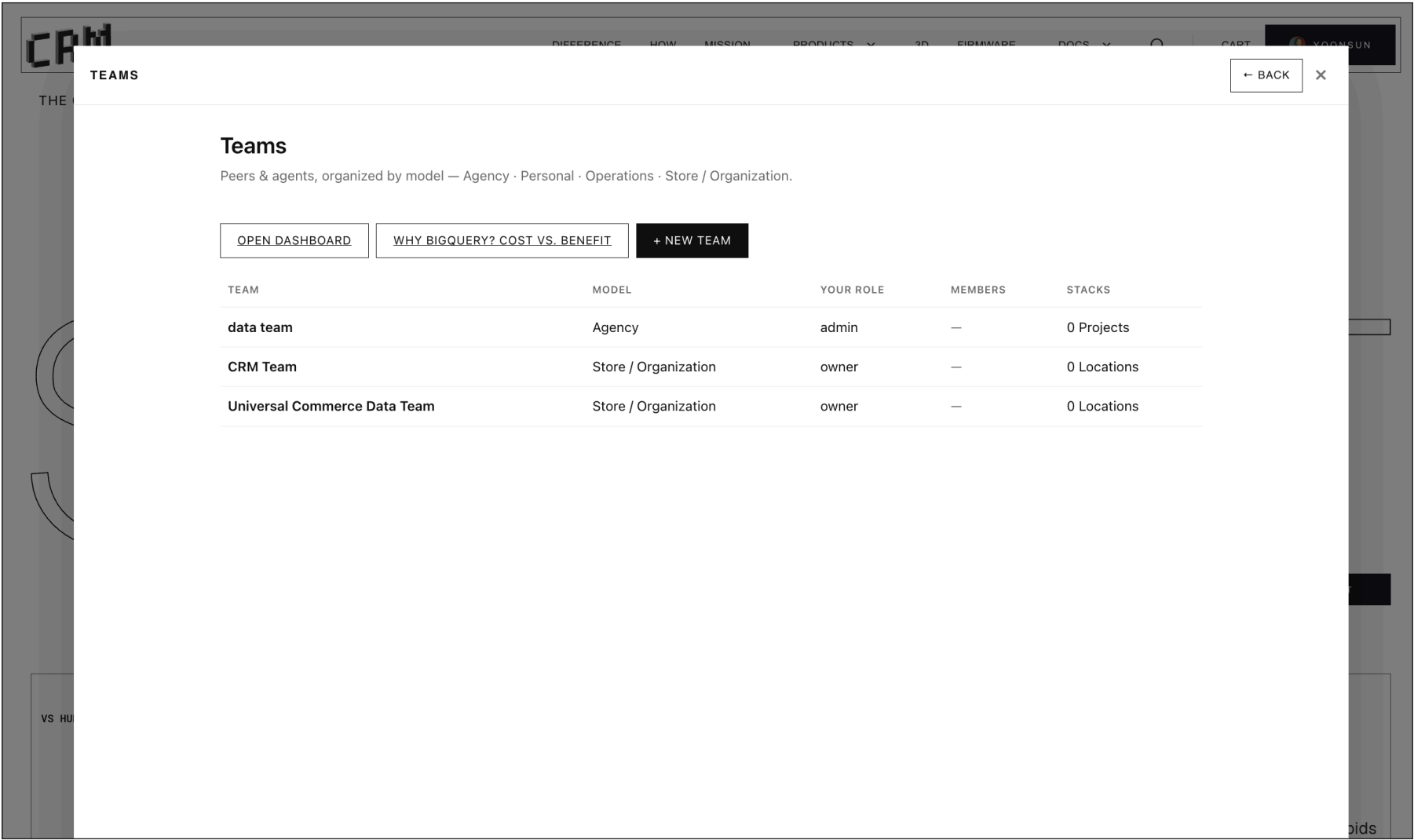
Team

Set up your team



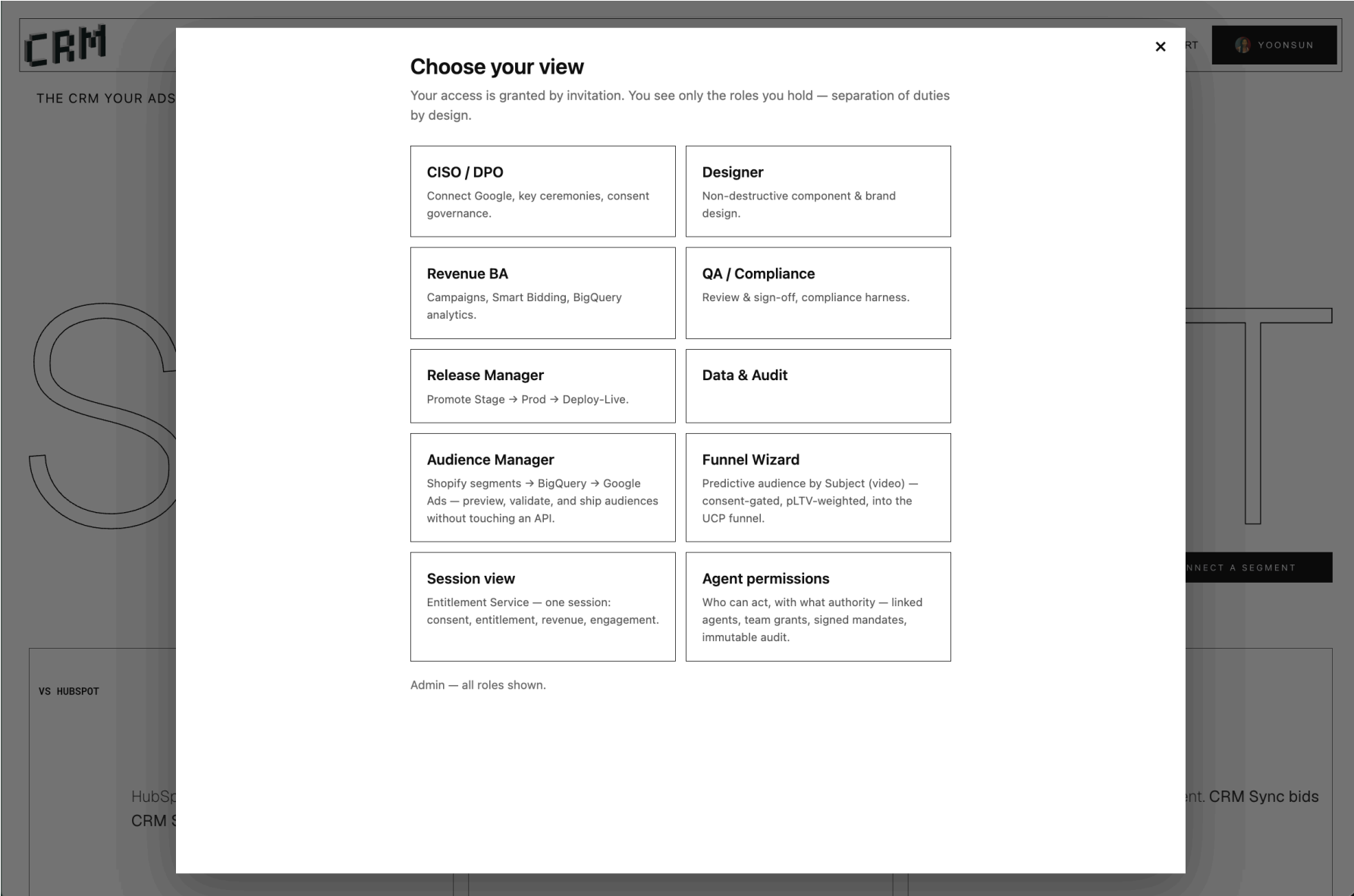
Teams

Create a team with permissions based on goal and access.



Teams

Create a team with permissions based on goal and access.



Sessions

Review Session Incident Reports

CRM

THE CRM YOUR ADS

VS HUBSPOT

HubSpot CRM Sync bids

ENTITLEMENT SERVICE — session view

segment-data.myshopify.com · enter a session ID to see its four consent-scoped panes.

session_id

a consent-event session UUID, e.g. b773f563-8c85-...

Open session

One session, four panes: 1P consent (grant / revoke / reset) · Shopify entitlement · multi-channel revenue (order + tax + ERP) · engagement (YouTube / social). The session is the unit, not the order.

YOONSUN

CONNECT A SEGMENT

Sessions

Review Session Incident Reports

CRM

THE CRM YOUR ADS

VS HUBSPOT

HubSpot CRM Sync

Entitlement Service — Session View

session_id: b773f563-8c85-4e7e-afdf-b3a365dd4228

crm-sync.dev · one session, four consent-scoped panes

1P Consent

GRANT / REVOKE / RESET

effective: **revoked**

reset at 1784459121000

projected (N+1): granted

at	event	state	category
1784459121000	crm_reset	granted	stack

Entitlement

SHOPIFY IDENTITY → CAPS

user_id 12

state active

features admin, designer

caps a2a, shops, brands, distribution

Revenue

ORDER + TAX + ERP

No rows for this session yet.

Engagement

YOUTUBE / SOCIAL

suppressed — consent revoked/reset for this identity (enforced from N+1); YouTube/social tracking withheld.

Who they are (entitlement), what they consented to and reset (1P consent), what they bought across channels + tax + ERP (revenue), how they engaged (engagement) — all keyed by session_id, all consent-scoped. The session is the unit, not the order.

YOONSUN

CONNECT A SEGMENT

ent. CRM Sync bids

Login Dashboard

CRM

DIFFERENCEHOWMISSIONPRODUCTS3DFIRMWAREDOCS

Q

CART

YOONSUN

THE CRM YOUR ADS AND AI AGENTS CAN USE — NOT JUST YOUR TEAM

SEGMENT

CONNECT A SEGMENT

VS HUBSPOT

HubSpot bolts AI onto the CRM you log into.

VS ATTIO

Attio is data-driven for your team. CRM Sync

VS KLAVIYO

Klaviyo emails the segment. CRM Sync bids

Setup Guide

Brand Studio

Get the App

Teams

Data Redaction

Choose your view

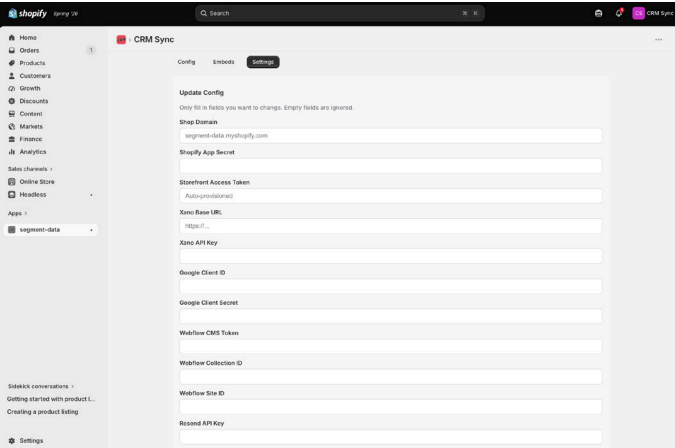
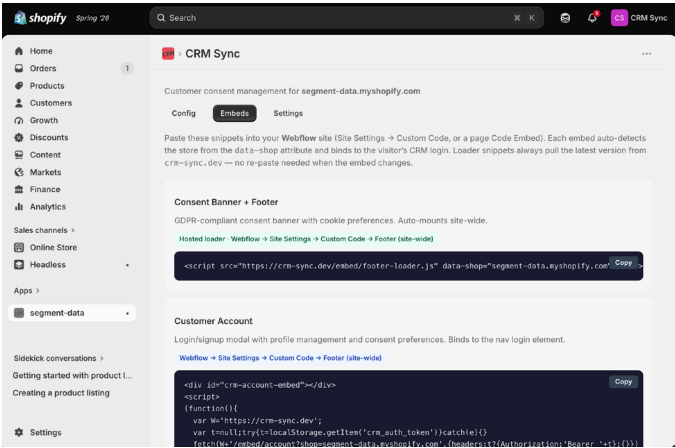
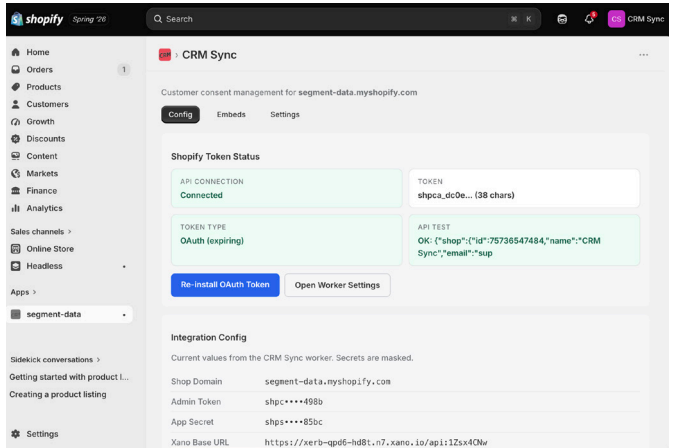
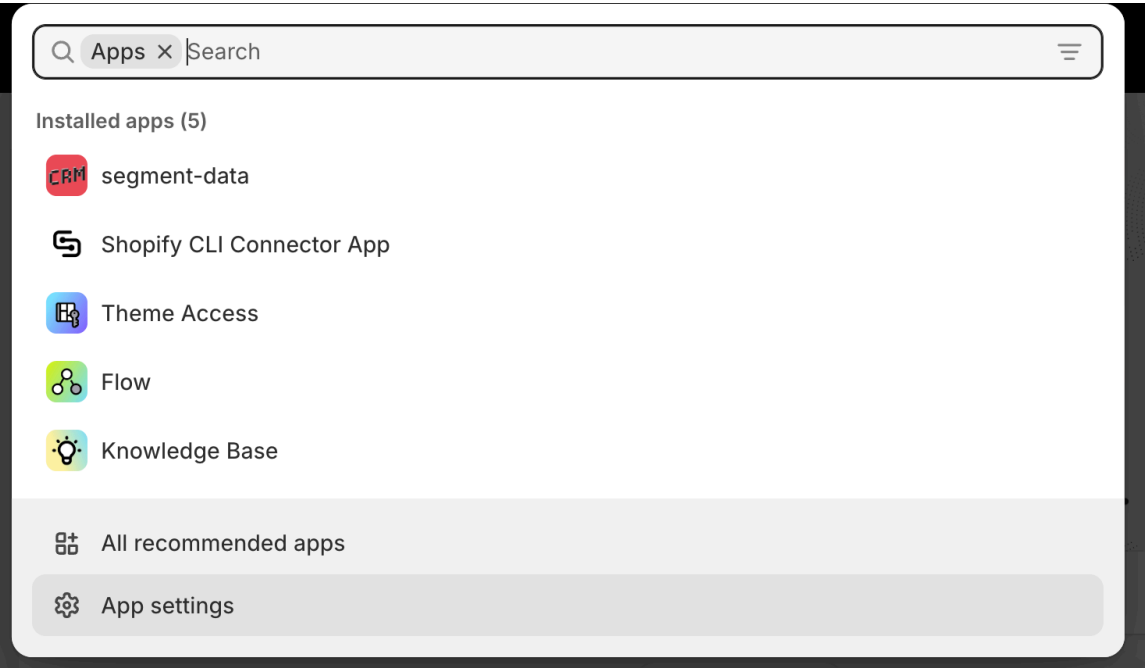
My Account & Privacy

Design

Log Out

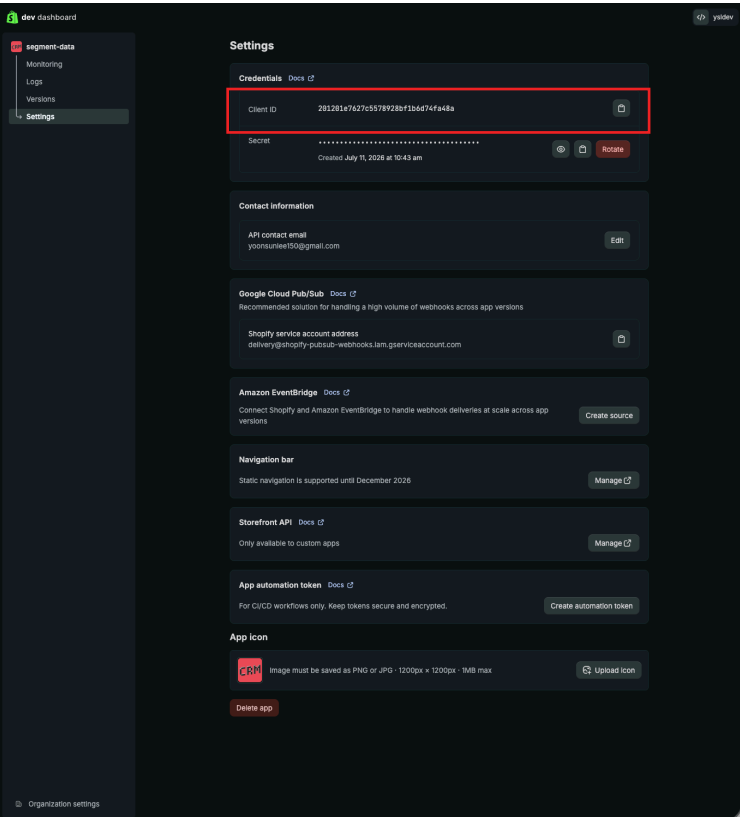
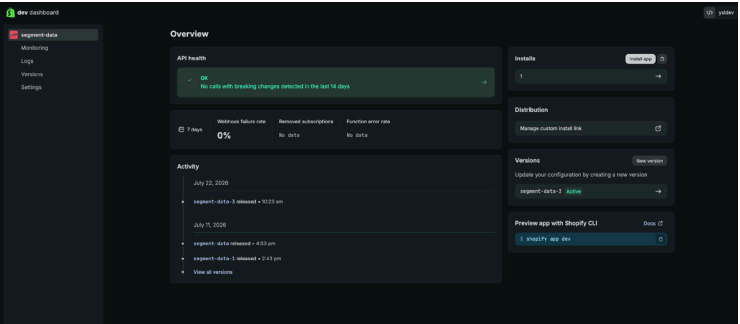
Shopify Apps

Our app-selection criterion for global scale: every installed app must be locale- and currency-aware, with no per-region metering. Apps built around a single-market assumption become the blocker when Shopify Markets turns on — so they don’t make the cut.

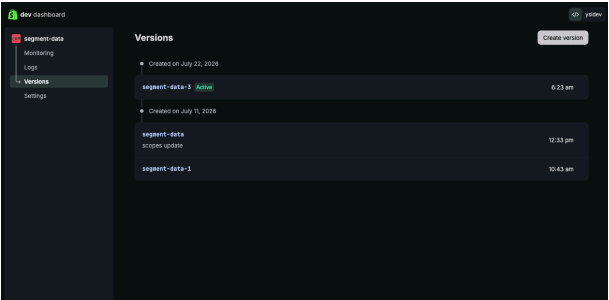
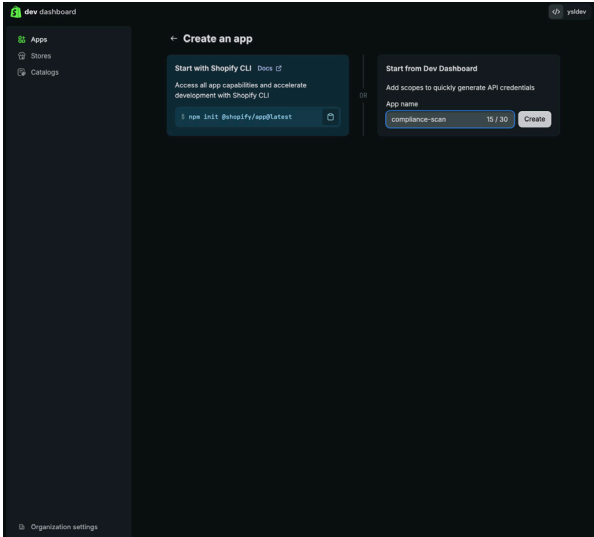


Shopify App

Cloudflare Worker



Public Key
that links with API/
AI connected data
without exposing
PII linked to Google
UUID



non-destructive
versioning

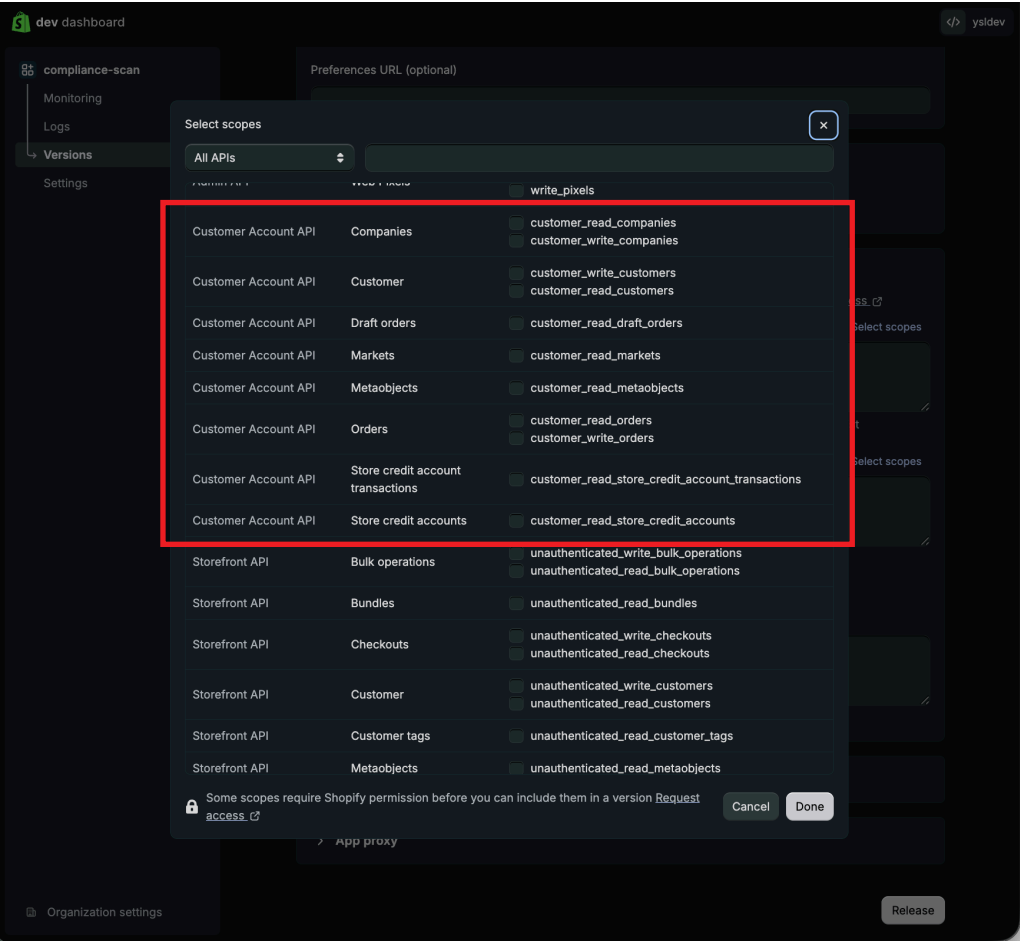
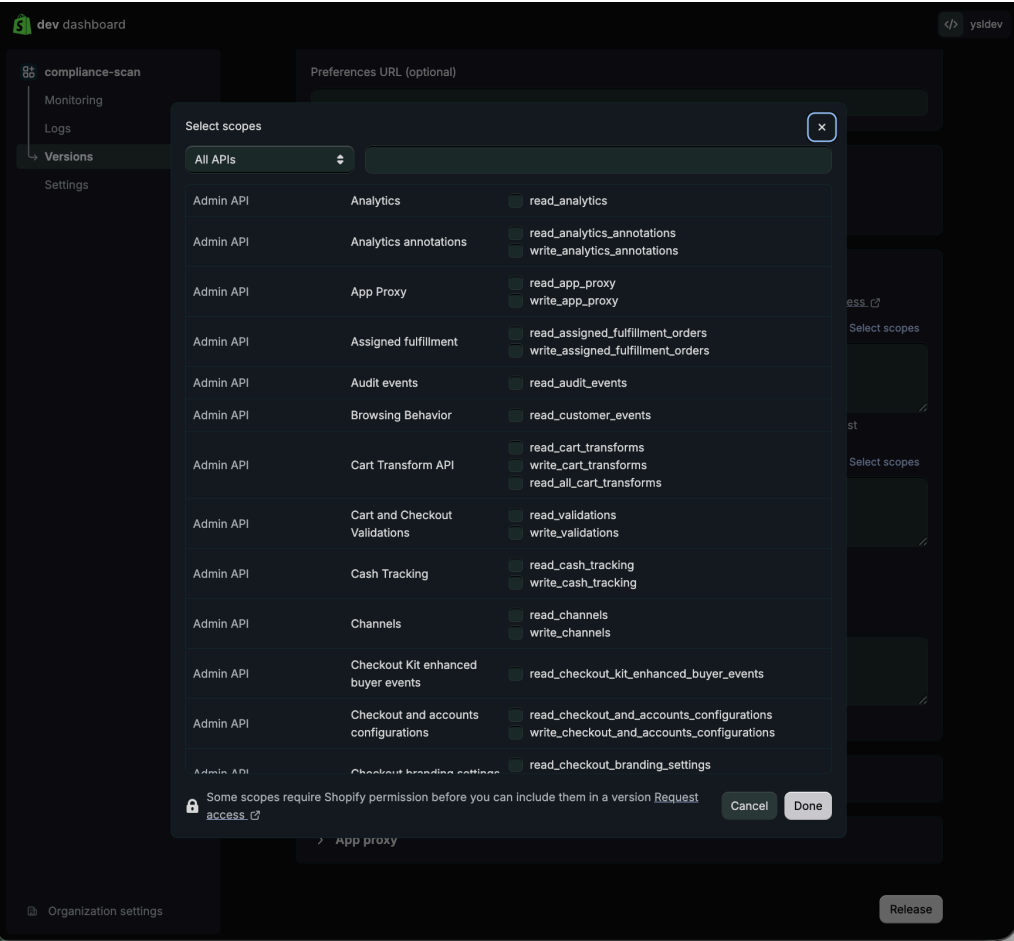
update live and A B versioned appli-
cation with timestamp/locale smart
app builds

Scoped App Data

Shopify curated user data privacy scoping

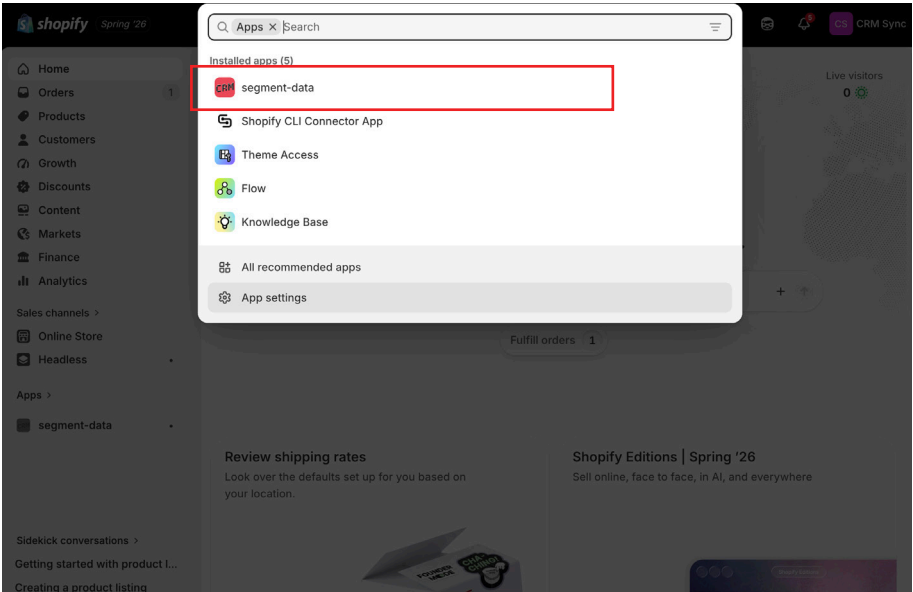
Shopify Privacy API

[HTTPS://SHOPIFY.DEV/DOCS/API/CUSTOMER-PRIVACY](https://shopify.dev/docs/api/customer-privacy)

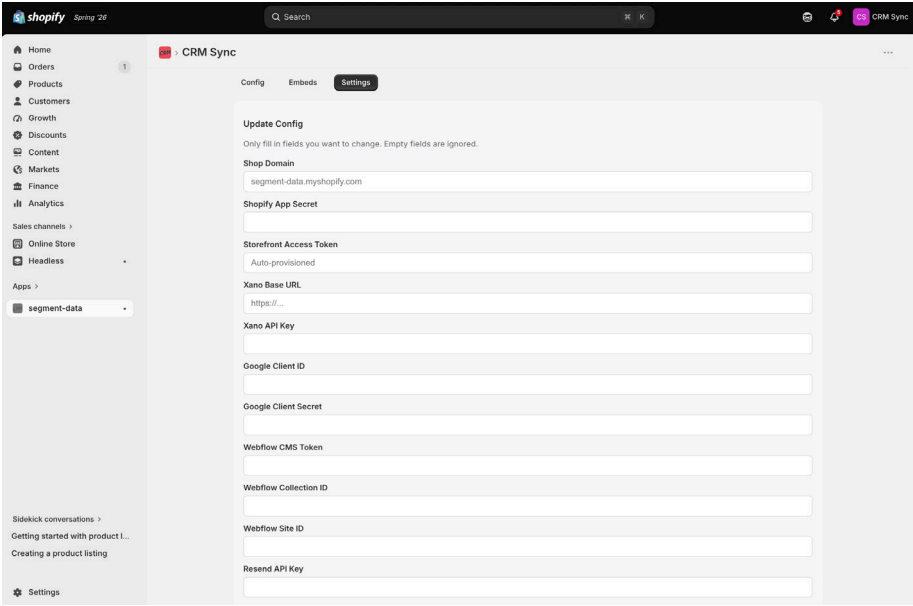
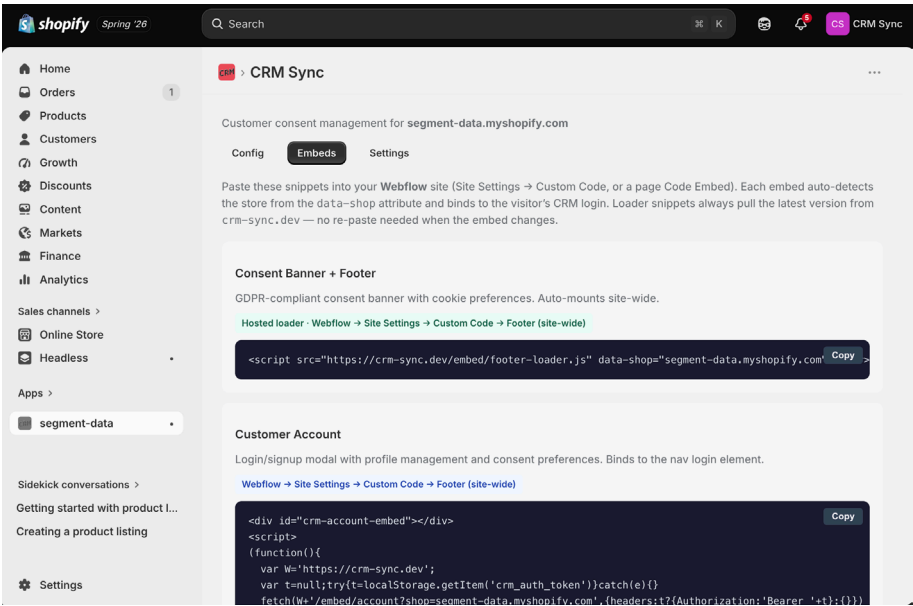
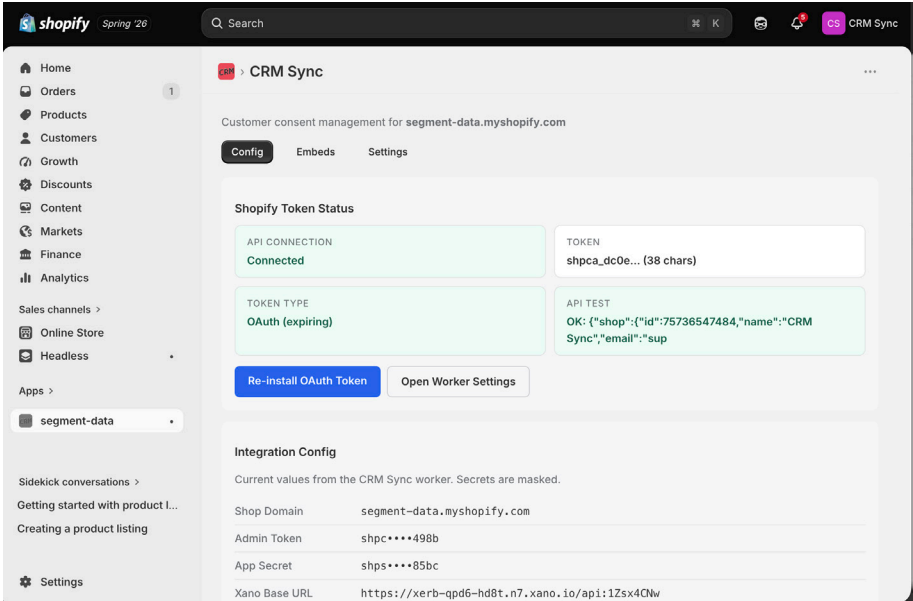


Testable bundles

Version managed with key rotation app publishing system



Version bundle application bundling on Server - Deploy as designed by Predictive Model rule/tool runner



Integrated Data

PIM/CRM/DAM/Consent is broadcast to connected omni channel stores and to GTM/Big Query

#	id	event_type	status	status_version	payload	consent_basis
1		consent.granted	granted		{act: ..., con: ...}	1.0
2		consent.granted	granted		{act: ..., con: ...}	1.0
3		consent.granted	granted		{act: ..., con: ...}	1.0
4		consent.granted	granted		{act: ..., con: ...}	1.0
5		consent.granted	granted		{act: ..., con: ...}	1.0
6		consent.granted	granted		{act: ..., con: ...}	1.0
7		consent.granted	granted		{act: ..., con: ...}	1.0
8		consent.allow	allow		{cha: ..., pur: ..., ...}	consent
9		return.received	received		{eff: [{typ: ..., l=...	
10		consent.granted	granted		{act: ..., con: ...}	1.0
11		consent.granted	granted		{act: ..., con: ...}	1.0
12		consent.revoked	revoked		{act: ..., con: ...}	1.0
13		consent.revoked	revoked		{act: ..., con: ...}	1.0
14		consent.revoked	revoked		{act: ..., con: ...}	1.0
15		consent.revoked	revoked		{act: ..., con: ...}	1.0
16		consent.revoked	revoked		{act: ..., con: ...}	1.0
17		consent.revoked	revoked		{act: ..., con: ...}	1.0
18		consent.granted	granted		{act: ..., con: ...}	1.0
19		consent.granted	granted		{act: ..., con: ...}	1.0
20		consent.granted	granted		{act: ..., con: ...}	1.0
21		consent.granted	granted		{act: ..., con: ...}	1.0
22		consent.granted	granted		{act: ..., con: ...}	1.0

The payload has the nested GraphQL Shopify Catalog with consent/locale/verification/session id/idempotent key/ on change timestamp and peer permissions built into the verified chain data shape

Data with AI Assist is checked for you

Right Shape for inbound and outbound destination as needed rules/function partnered with Cloudflare Worker DDOS/WAF Boundary per row

The Designer or the BA/QA/PMO doesn't need to worry about the data, AI will test it for you

API Group Name
SamsungPay #69
omnibus #68
Entitlement #67
PIM Sync #66
CollectionSync #65

This was a Headless Next JS project import from AWS 90 GB of Assets that took Matrixify 10 hours to transfer to Shopify

Shopify API Leaky bucket died after 2500 rows, the API unlimited background task reshaped 30,000 rows per migration with images/ALT tags

Xano did the conversion plus nesting 'Parent Child' from Feedonomics in 4 minutes

70,000 rows of API calls are saved as AI Webhook per call transformation that would be Egress Fee from AWS/ Vercel that is on AWS and Supabase also on AWS

There is zero fee for Webflow/Shopify that shares Cloudflare to data store

gp_webhook_queue #169	40 MB	70,079
kb_articles #204	3 MB	116
kb_i18n #207	213 kB	1
kb_i18n_log #208	213 kB	9
kb_images #205	590 kB	81
kb_manufact #206	360 kB	13
legal_docs #227	262 kB	2
linked_agents #188	213 kB	1
market_of_sale #228	246 kB	1
market_variant #171	213 kB	1
merchant_config #176	418 kB	9
omnibus_evidence #232	418 kB	9
Orders #49	147 kB	9
pos_metrics #197	106 kB	0
price_history #172	74 kB	0
product_master #170	74 kB	0
Products #48	15 MB	6,337
reconciliation_log #196	442 kB	106
richtext #83	1 MB	206
rma_requests #210	213 kB	1

ucp_funnel_history #212	565 kB	125
User #46	180 kB	2
user_oauth #42	90 kB	0
user_claims #181	303 kB	36
user_extras #182	270 kB	26
user_tag_map #186	344 kB	1
uuid_signal_status #199	213 kB	2
webflow_conflicts #178	57 kB	0
webflow_site_items #209	516 kB	197
Total	111 MB	81,480

Polling Data

Xano connected to Shopify / Webflow interface with Row Level Function Publish

PIM

Free Plan

Connect this backend

Search and run commands

YL

0

Publish

ucp_funnel_history # 212

Share

Trigger

Build with Agent

Change View

Search

Filter

Sort

Hide Fields

Dashboard

Database

Agents & MCP

Tasks

Middleware

Triggers

Keys & Variables

Knowledge

#	id	A event_type	A status	# status_version	{ payload	A consent_basis
☐	1	consent.granted	granted		0 {act.: →, con.: →}	1.0
☐	2	consent.granted	granted		0 {act.: →, con.: tos}	1.0
☐	3	consent.granted	granted		0 {act.: →, con.: tos}	1.0
☐	4	consent.granted	granted		0 {act.: →, con.: →}	1.0
☐	5	consent.granted	granted		0 {act.: →, con.: →}	1.0
☐	6	consent.granted	granted		0 {act.: →, con.: →}	1.0
☐	7	consent.granted	granted		0 {act.: →, con.: _ts}	1.0
☐	8	consent.allow	allow		0 {cha.: →, pur.: →, → consent	
☐	9	return.received	received		0 {eff.: [{typ.: →, l...	
☐	10	consent.granted	granted		0 {act.: →, con.: tos}	1.0
☐	11	consent.granted	granted		0 {act.: →, con.: tos}	1.0
☐	12	consent.revoked	revoked		0 {act.: →, con.: →}	1.0
☐	13	consent.revoked	revoked		0 {act.: →, con.: →}	1.0
☐	14	consent.revoked	revoked		0 {act.: →, con.: →}	1.0
☐	15	consent.revoked	revoked		0 {act.: →, con.: →}	1.0
☐	16	consent.revoked	revoked		0 {act.: →, con.: →}	1.0
☐	17	consent.revoked	revoked		0 {act.: →, con.: →}	1.0
☐	18	consent.granted	granted		0 {act.: →, con.: _ts}	1.0
☐	19	consent.granted	granted		0 {act.: →, con.: _ts}	1.0
☐	20	consent.granted	granted		0 {act.: →, con.: tos}	1.0
☐	21	consent.granted	granted		0 {act.: →, con.: →}	1.0
☐	22	consent.granted	granted		0 {act.: →, con.: →}	1.0

+ Add new record

Generate records

CRM

DIFFERENCE HOW MISSION PRODUCTS 3D FIRMWARE DOCS Q CART

YODANEUN

THE CRM YOUR ADS AND AI AGENTS CAN USE — NOT JUST YOUR TEAM

Granted	Terms	Proof
2026-07-27	distribution	receipt - verify - QR - SVG
2026-07-27	distribution	receipt - verify - QR - SVG

ACTIVITY LOG

Date	Interaction	Via
2026-07-22 15:58	consent granted	deferred_login
2026-07-22 15:58	consent granted	deferred_login
2026-07-22 15:58	consent granted	deferred_login
2026-07-22 15:58	consent granted	deferred_login
2026-07-22 15:58	Consent granted	
2026-07-22 15:58	Consent granted	
2026-07-22 15:58	Consent granted	
2026-07-22 15:58	Consent granted	deferred_login
2026-07-21 16:45	consent granted	deferred_login
2026-07-21 16:45	consent granted	deferred_login
2026-07-21 16:45	Consent granted	
2026-07-21 16:45	Consent granted	
2026-07-21 16:45	Consent granted	
2026-07-21 16:45	Consent granted	deferred_login

Verify

Timeline Attestations, QR, SVG files

CRM

DIFFERENCEHOWMISSIONPRODUCTS3DFIRMWAREDOCSQCARTYOONSUN

THE CRM YOUR ADS AND AI AGENTS CAN USE — NOT JUST YOUR TEAM

Granted	Terms	Proof
2026-07-27	distribution	receipt · verify · QR · SVG
2026-07-27	distribution	receipt · verify · QR · SVG

ACTIVITY LOG

Date	Interaction	Via
2026-07-22 15:58	consent granted	deferred_login
2026-07-22 15:58	consent granted	deferred_login
2026-07-22 15:58	consent granted	deferred_login
2026-07-22 15:58	consent granted	deferred_login
2026-07-22 15:58	Consent granted	
2026-07-22 15:58	Consent granted	
2026-07-22 15:58	Consent granted	
2026-07-22 15:58	Consent granted	
2026-07-22 15:58	Consent granted	
2026-07-22 15:58	consent granted	deferred_login
2026-07-21 16:45	consent granted	deferred_login
2026-07-21 16:45	consent granted	deferred_login
2026-07-21 16:45	Consent granted	
2026-07-21 16:45	Consent granted	
2026-07-21 16:45	Consent granted	
2026-07-21 16:45	Consent granted	
2026-07-21 16:45	consent granted	deferred_login

Attestations

Verified, Timestamp, Consent Assets on Chained Data Events Publishing

Receipt

```

pretty-print
{"ok":true,"verified":true,"record":{"event":"license.granted","order_ref":"manual:1785134744192","grantor":"segment-data.myshopify.com","terms":{"caps":
"distribution"},"features":[],"scope":{"brands":"*"},"consent":
"version":"1.0"},"tos":true,"privacy":true,"cookie":true,"marketing":true,"as_of":{"1784735860000},"subject":{"12"},"ts":{"2026-07-
27T06:45:44.725Z"},"prev_hash":{"32b80e"},"certificate":{"eyJhbGc

```

Verify

```
python3 -c "import json; print(json.dumps({'valid':true,'kid':'esk_5ffc138c-4525-4f1c-a530-8a5fa905f026','jti':'daa6ca54-262f-4174-9b35-5caff3250972','alg':'EdDSA'},'claims':{'iat':1786134745,'nbf':1785134745,'exp':2100494745},'jti':'daa6ca54-262f-4174-9b35-5caff3250972'),'license':{'subject':'Prescore hash','iss':'Terms','capa':{'distribution':{'features':[{'consent':{'version':'1.0'}],'tos':true,'privacy':true,'cookie':true,'marketing':true},'as_of':'1784533868000','issued':'2026-07-2786134745','id':'1786134745','grants':{'segment':'data-myshopify.com','verified_at':'2026-07-2786134745-46138-0000','register_url':'https://creativecommons.org/licenses/verifications?jti='},'_note':'signature verified against the published public key (JWSK) - issued by the platform's ceremony-held key, terms unaltered'})})")
```

QR



EdDSA vs Nstor

Use Key Ceremony already in use by Financial Institutions

Your setup: asymmetric keys with named generations. The EdDSA license keys are keypairs. The private half is held only through the key ceremony (human executes; the key never enters agent context or logs), and the public half is published in the JWKS under a `kid`. Rotation is non-disruptive by construction: mint a new keypair with a new `kid`, publish old and new public keys side by side, sign new licenses with the new key. Old licenses keep verifying – their header names the old `kid`, which is still in the JWKS – until they expire and the retired key is dropped. There's never a flag day. Ejecting a single credential doesn't require touching keys at all: `crm_t` tenant tokens are individually revocable, and license `jti`s are checkable against the registry. The one symmetric exception is `JWT_SECRET` – rotating that *does* invalidate every session at once, which is why it's the blunt instrument, not the routine tool.

Buzz-style channel keys: possession is membership. There, the key is a shared symmetric secret and holding it is both your identity and your access – distribution of the key *is* the grant. That gives you the properties your Teams comment is riffing on, but rotation is where it hurts: there are no key generations and no overlap window, so rotating means generating a new channel key and redistributing it to everyone who should remain – a coordinated re-key, and the only way to eject one member. And it's not retroactive: anyone who ever held the old key could read everything encrypted under it. There's also no third-party verifiability – an outsider can't check that a membership or message was legitimate, which is the property your JWKS + public verification registry exists to provide.

The deliberate split in your code is that you adopted Buzz's *visibility* semantics without its *authority* semantics. Team invitation grants read access to peer mints – that's the Buzz-relay part – but authority stays in the capability system: minting still requires the caller's own `caps.distribution`, and "invitation never amplifies authority" (your R1 rule). So membership churn is handled by live resolution (a peer leaving just hides rows again), not by re-keying anything – because the keys that carry authority live in the rotation/ceremony plane, not in the channel.

Granted	Terms	Proof
2026-07-27	distribution	receipt · verify · QR · SVG
2026-07-27	distribution	receipt · verify · QR · SVG

This is the record The token is the container carrying the claims; the KID is the label naming which published key to check it against; EdDSA is the verification.

Pretty-print ☐

```
{"valid":true,"kid":"esk_51fc138c-4525-4f1c-a530-8a5fa905f026","jti":"daa6ca54-262f-4174-9b35-5caff3250972","alg":"EdDSA","claims":{"iat":1785134745,"nbf":1785134745,"exp":2100494745,"jti":"daa6ca54-262f-4174-9b35-5caff3250972","t":"license","subject":"12","record_hash":"2a80","terms":{"caps":["distribution"],"features":[]},"consent":{"version":"1.0","tos":true,"privacy":true,"cookie":true,"marketing":true,"as_of":1784735886000},"issued":"2026-07-27T06:45:44.725Z","order_ref":"manual:1785134744192","grantor":"segment-data.myshopify.com"},"verified_at":"2026-07-28T06:41:47.407Z","register_url":"https://crm-sync.dev/license/verifications?jti=daa6ca54-262f-4174-9b35-5caff3250972","note":"signature verified against the published public key (JWKS) – issued by the platform's ceremony-held key, terms unaltered"}}
```

Firmware Glossary

Firmware Glossary
<https://crm-sync.dev/r/afb95mm>

Term	Definition	Anchor	URL
MIME type	A two-part type/subtype label a server sends so a client knows how to handle a file's bytes. The vault stores the declared MIME type as meta-data but never lets it drive rendering — downloads are forced and sniffing is blocked (see nosniff). Accepted upload types: .exe application/vnd.microsoft.portable-executable — Windows PE executable.bin · .img · .dfu · .fw application/octet-stream — raw firmware image; no browser-known type.hex Intel HEX (ASCII); served as octet-stream.zip application/zip.tar application/x-tar.gz application/gzip.stl model/stl — 3D print mesh.glb model/gltf-binary.gltf model/gltf+json.obj model/obj.3mf model/3mf — 3D Manufacturing Format	#g-mime	https://www.crm-sync.dev/pages/firmware#g-mime
Immutable vaulting	A vaulted version is a fact, not a mutable file. A new build is a new record (product-fw-version), never an overwrite — re-vaulting an existing slug is refused (409). This is what makes the SHA-256 a permanent identity.	#g-im-mutable	https://www.crm-sync.dev/pages/firmware#g-immutable
8 MB browser cap	The in-page uploader caps at 8 MB. Larger images push through the API (POST /firmware/vault) or the CI relay — the cap is a browser-memory limit, not a product limit.	#g-cap	https://www.crm-sync.dev/pages/firmware#g-cap
Envelope encryption (vaulting)	Each image is encrypted under a random per-image content key; that key is itself encrypted (“wrapped”) under a versioned derived key. Cipher-text and wrapped key are stored apart — useless alone. Storage compromise yields ciphertext, not firmware.	#g-vault	https://www.crm-sync.dev/pages/firmware#g-vault
AES-256-GCM	The symmetric cipher used for the payload: 256-bit key, authenticated (GCM) so tampering is detectable on decrypt. Applied before anything is written to storage.	#g-aes	https://www.crm-sync.dev/pages/firmware#g-aes
CEK / KEK	Content-Encryption Key (encrypts the image, one per image) and Key-Encryption Key (wraps the CEK, versioned). Separating them means a suspected leak is healed by re-wrapping under a new KEK version — the ciphertext never moves.	#g-cek-kek	https://www.crm-sync.dev/pages/firmware#g-cek-kek
Ed25519 certificate	A signed attestation binding product, version, digest, uploader, and linked SBOM at vault time. Anyone verifies it against the public JWKS — no account, no trust in the platform required.	#g-ed25519	https://www.crm-sync.dev/pages/firmware#g-ed25519
Hash-chained ledger	Every upload, grant, denial, and served byte-stream is a row whose hash includes the row before it. History can't be quietly edited — only visibly broken. This is the factual basis of CRA incident reporting.	#g-ledger	https://www.crm-sync.dev/pages/firmware#g-ledger
Key rotation (healing)	A suspected leak is answered by bumping the key version and re-wrapping the CEK. Ciphertext is untouched; every previously issued wrapped key and download token dies at once — remediation without a recall.	#g-rotation	https://www.crm-sync.dev/pages/firmware#g-rotation
Grant (grant-gated)	Download access is a capability held by a subject — a person, teammate, or agent — not a shareable link. It is granted, audited, and revoked per subject in real time; every grant and denial lands in the ledger.	#g-grant	https://www.crm-sync.dev/pages/firmware#g-grant
PKCE	Proof Key for Code Exchange — proves the human at sign-in with no client secret to steal. Half of the double-key identity model.	#g-pkce	https://www.crm-sync.dev/pages/firmware#g-pkce
JWE	JSON Web Encryption — seals the actor's identity so it is only ever read server-side. The other half of the identity model; the token is never legible in the browser.	#g-jwe	https://www.crm-sync.dev/pages/firmware#g-jwe
JWKS	The public key set at /.well-known/jwks.json that anyone uses to verify a certificate. Published; carries no private key material.	#g-jwks	https://www.crm-sync.dev/pages/firmware#g-jwks
CORS (restricted)	Cross-Origin Resource Sharing — the browser rule that a page on one origin may only read another origin's response if that server opts in via Access-Control-Allow-Origin. Here it is paired with restricted embedding : a vaulted image's proof badge loads only on the domains you allowlist in the Access tab (empty = any). The encrypted payload itself is never cross-origin readable — it is single-use, server-decrypted, and delivered as a forced download.	#g-cors	https://www.crm-sync.dev/pages/firmware#g-cors
nosniff	X-Content-Type-Options: nosniff tells the browser not to guess a response's type and override the declared one. On the payload path it stops a file from being reinterpreted as HTML or script.	#g-nosniff	https://www.crm-sync.dev/pages/firmware#g-nosniff
Content-Disposition: attachment	Instructs the browser to download a response rather than render it in place. Every decrypted payload is served this way, so a file can never execute on our origin — the serve-path defense against stored XSS.	#g-disposition	https://www.crm-sync.dev/pages/firmware#g-disposition
SBOM	Software Bill of Materials — a machine-readable ingredient list (CycloneDX or SPDX) for an app release or firmware image, generated in CI so it stays current. The registry is where they live.	#g-sbom	https://www.crm-sync.dev/pages/firmware#g-sbom
Cyber Resilience Act	EU Regulation 2024/2847. Reporting obligations begin 11 Sep 2026; full obligations 11 Dec 2027. It assumes an evidence chain — SBOMs, provenance, an access record — that this service produces as a by-product of normal use.	#g-cra	https://www.crm-sync.dev/pages/firmware#g-cra
CycloneDX	An SBOM format (ECMA-424). The default the registry generates and vulnerability-scans.	#g-cyclonedx	https://www.crm-sync.dev/pages/firmware#g-cyclonedx
SPDX	An SBOM format (ISO/IEC 5962). Accepted alongside CycloneDX; either satisfies the CRA SBOM row.	#g-spdx	https://www.crm-sync.dev/pages/firmware#g-spdx